CISSP 600

Security Assessment and Testing



AL NAFI,
A company with a focus on education, wellbeing and renewable energy.

© 2018 Al-Nafi. All Rights Reserved.

Forty Hadith on the importance of Knowledge, learning and Teaching.

© 2018 Al-Nafi. All Rights Reserved.

Hadith # 13 Allah's Path

Anas (may Allah be pleased with him) said: The Messenger of Allah (Peace Be upon Him) Said:

"He who leave his home in order to seek knowledge, he is in Allah's path until he returns [to his home]."

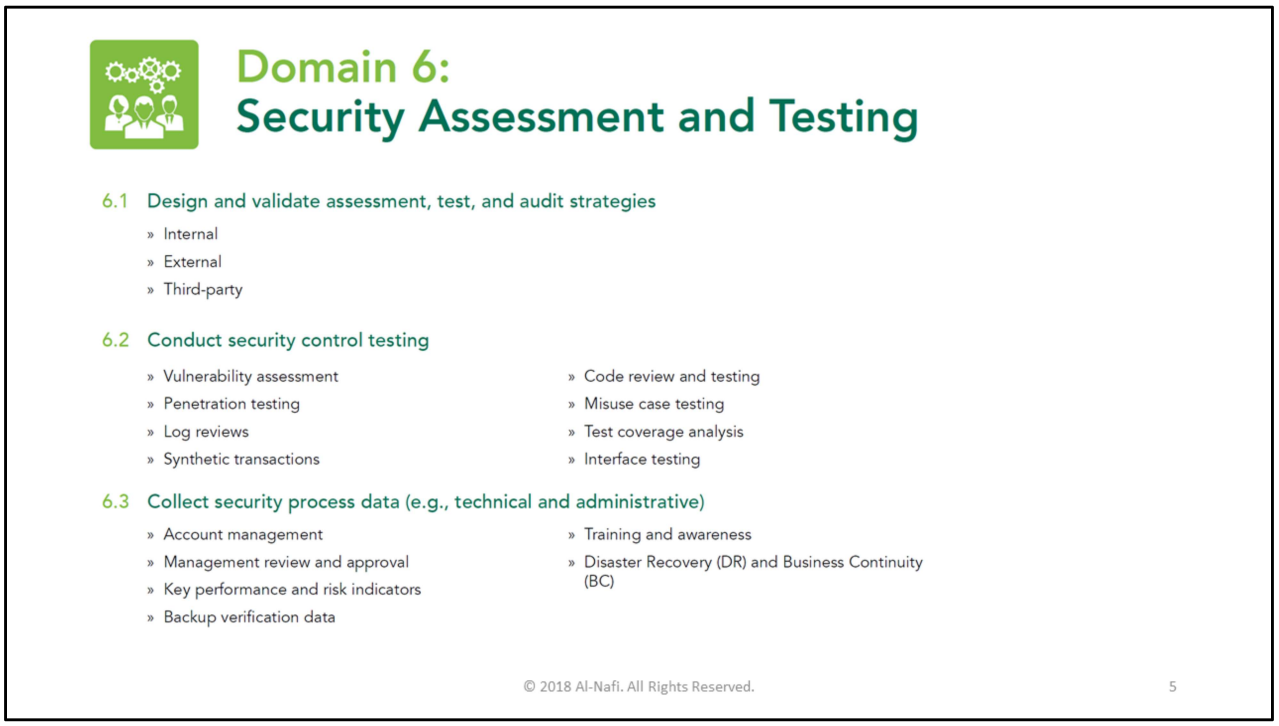
(at-Tirmidhi, Sunan; An-Nawawi, Riyad as-Salihin)

© 2018 Al-Nafi. All Rights Reserved.

How Nafi Members Study!

1. Please subscribe to our YouTube channel https://www.youtube.com/channel/UC2yAW4Oq27r1yuRE8ePKRvA
2. Follow us on Facebook https://www.facebook.com/info.alnafi/
3. Follow us on Twitter https://twitter.com/nafiPakistan
4. All Nafi members MUST study on the portal https://alnafi.com/login/ and connect using your Nafi member username and password. If you have problems connecting then please contact us via info@alnafi.com
5. To ask questions as it relates to studies please join our group https://www.facebook.com/groups/alnafi/
6. Once on the portal they can follow their classes by:
    - watching videos
    - asking questions
    - attempting quizzes and flash cards
    - studying official Nafi notes
    - keep track of their studies long with many more features

© 2018 Al-Nafi. All Rights Reserved.



Security testing and assessment are activities that assist an organization in managing risk, developing applications, managing systems, and utilizing services. To be successful in mitigating risks, organizations must develop competencies that align with business needs related to assessing, validating, testing, and auditing systems and applications that support business objectives and goals.



Domain 6:
Security Assessment and Testing

6.4 Analyze test output and generate report

6.5 Conduct or facilitate security audits

- Internal
- External
- Third-party

© 2018 Al-Nafi. All Rights Reserved.

Design and Validate Assessment, Test, and Audit Strategies

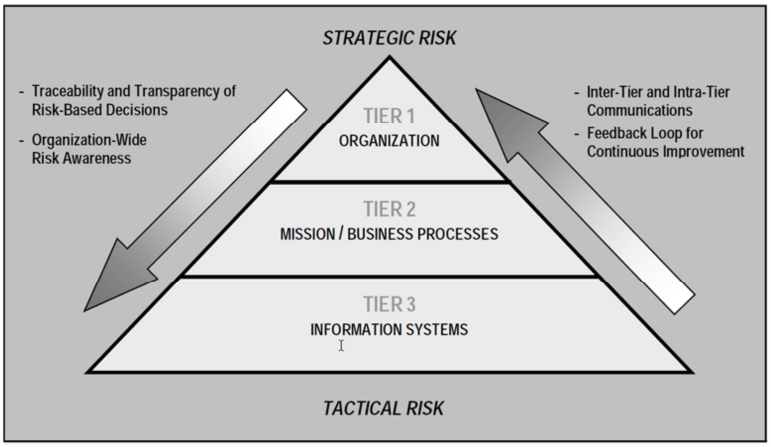
Security and Privacy Controls for Federal Information Systems and Organizations

Need to download and read this document:

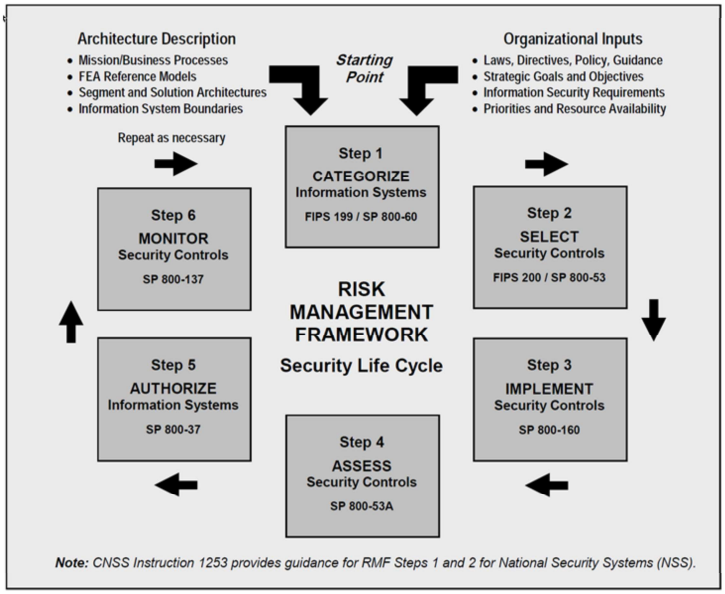
https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf

© 2018 Al-Nafi. All Rights Reserved.

Design and Validate Assessment, Test, and Audit Strategies



© 2018 Al-Nafi. All Rights Reserved.



© 2018 Al-Nafi. All Rights Reserved.

Internal Actors/Threats

Insider Threat Study: Illicit Cyber Activity Involving Fraud in the U.S. Financial Services Sector

Adam Cummings
Todd Lewellen
David McIntire
Andrew P. Moore
Randall Trzeciak

July 2012

SPECIAL REPORT
CMU/SEI-2012-SR-004

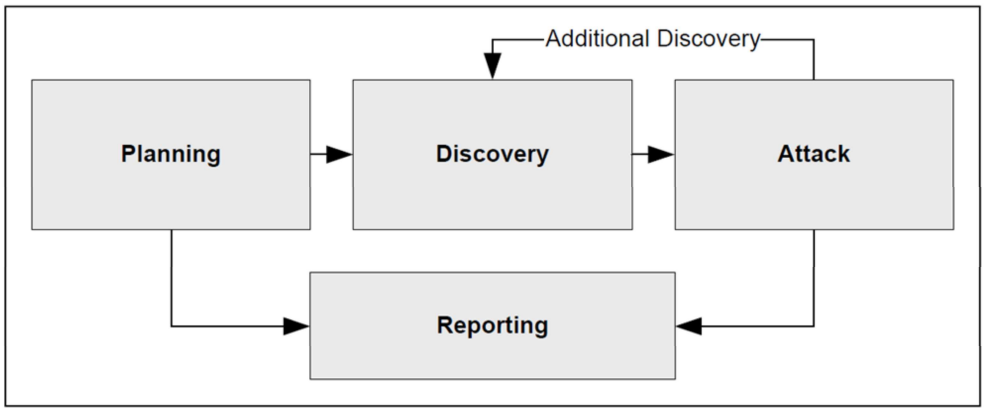
CERT Program
http://www.sei.cmu.edu



© 2018 Al-Nafi. All Rights Reserved.

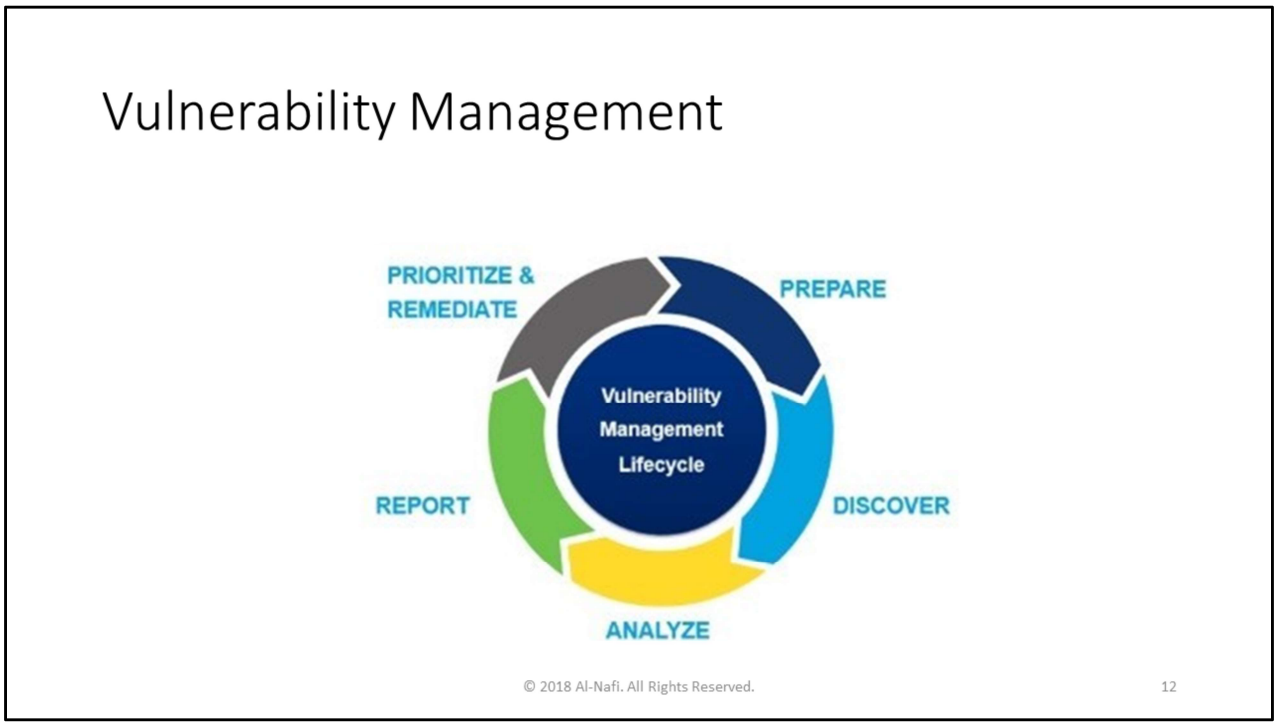
Please download and study this study
https://resources.sei.cmu.edu/asset_files/SpecialReport/2012_003_001_28137.pdf

Technical Guide to Information Security Testing and Assessment **Special Publication 800-115**



© 2018 Al-Nafi. All Rights Reserved.

https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-115.pdf please download and read this document further.



12.6 Technical vulnerability management
Objective: To prevent exploitation of technical vulnerabilities.

12.6.1 Management of technical vulnerabilities
Control
Information about technical vulnerabilities of information systems being used should be obtained in a timely fashion, the organization's exposure to such vulnerabilities evaluated and appropriate measures taken to address the associated risk.

Implementation guidance
A current and complete inventory of assets (see Clause 8) is a prerequisite for effective technical vulnerability management. Specific information needed to support technical vulnerability management includes the software vendor, version numbers, current state of deployment (e.g. what software is installed on what systems) and the person(s) within the organization responsible for the software.

Appropriate and timely action should be taken in response to the identification of

potential technical vulnerabilities. The following guidance should be followed to establish an effective management process for technical vulnerabilities:
a) the organization should define and establish the roles and responsibilities associated with technical vulnerability management, including vulnerability monitoring, vulnerability risk assessment,
patching, asset tracking and any coordination responsibilities required;
b) information resources that will be used to identify relevant technical vulnerabilities and to maintain awareness about them should be identified for software and other technology (based on the asset inventory list, see 8.1.1); these information resources should be updated based on changes in the inventory or when other new or useful resources are found;
c) a timeline should be defined to react to notifications of potentially relevant technical vulnerabilities;
d) once a potential technical vulnerability has been identified, the organization should identify the associated risks and the actions to be taken; such action could involve patching of vulnerable
systems or applying other controls;
e) depending on how urgently a technical vulnerability needs to be addressed, the action taken should be carried out according to the controls related to change management (see 12.1.2) or by following information security incident response procedures (see 16.1.5);
f) if a patch is available from a legitimate source, the risks associated with installing the patch should be assessed (the risks posed by the vulnerability should be compared with the risk of installing the patch);
g) patches should be tested and evaluated before they are installed to ensure they are effective and do not result in side effects that cannot be tolerated; if no patch is available, other controls should be considered, such as:
1) turning off services or capabilities related to the vulnerability;
2) adapting or adding access controls, e.g. firewalls, at network borders (see 13.1);
3) increased monitoring to detect actual attacks;
4) raising awareness of the vulnerability;
h) an audit log should be kept for all procedures undertaken;
i) the technical vulnerability management process should be regularly monitored and evaluated in order to ensure its effectiveness and efficiency;
j) systems at high risk should be addressed first;
k) an effective technical vulnerability management process should be aligned with incident management activities, to communicate data on vulnerabilities to the incident response function
and provide technical procedures to be carried out should an incident occur;
l) define a procedure to address the situation where a vulnerability has been identified but there is no suitable countermeasure. In this situation, the organization

should evaluate risks relating to the known vulnerability and define appropriate detective and corrective actions.

Other information
Technical vulnerability management can be viewed as a sub-function of change management and as such can take advantage of the change management processes and procedures (see 12.1.2 and 14.2.2). Vendors are often under significant pressure to release patches as soon as possible. Therefore, there is a possibility that a patch does not address the problem adequately and has negative side effects. Also, in some cases, uninstalling a patch cannot be easily achieved once the patch has been applied.

Pentesting or offensive hacking or ethical hacking



© 2018 Al-Nafi. All Rights Reserved.

Pentesting steps



© 2018 Al-Nafi. All Rights Reserved.

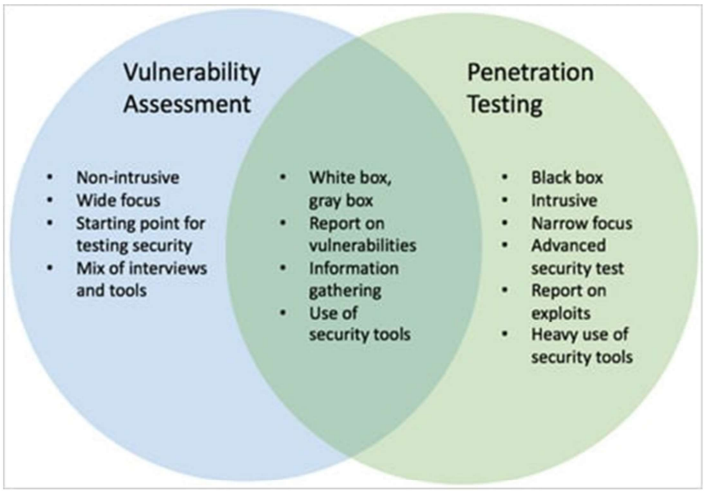
B.29 Pentest and vulnerability assessment

Information descriptor	Meaning or purpose
Measure ID	Organization-defined
Information need	To evaluate whether information systems handling sensitive data (confidentiality, integrity) are vulnerable to malicious attacks
Measure	Percentage of critical information systems where a penetration test or vulnerability assessment has been executed since their last major release
Formula/scoring	[Number of information systems quantified as critical and where a penetration test or vulnerability assessment has been done since their last major release/ Number of information systems quantified as critical] * 100, e.g. Green: 100%, Orange >=75%, Red <75%
Target	Orange (Green would be too perfect)
Implementation evidence	Reports of penetration tests or vulnerability assessments performed on information systems compared to number of information systems classified as critical in the asset inventory
Frequency	Collect: yearly Report: for each collection
Responsible parties	Information owner: Risk owner Information collector: Experts with the know-how to conduct penetration tests or execute vulnerability assessments Measurement client: Chief information security officer
Data source	Asset inventory, penetration test reports
Reporting format	Pie chart for current situation and line chart for compliance evolution representation

Relationship	ISO/IEC 27001:2013, A.12.6.1: Management of technical vulnerabilities ISO/IEC 27001:2013, A.18.2.3: Technical compliance review

© 2018 Al-Nafi. All Rights Reserved.

Vulnerability assessment vs. Pentesting



© 2018 Al-Nafi. All Rights Reserved.